PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation des bases de données relationnelles

03-240 ANSSI - Bases de données relationnelles — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le SGBD doit être maintenu à jour via les dépôts officiels.
2. Le principe de moindre privilège consiste à limiter les droits des utilisateurs au strict nécessaire via des rôles.
3. L'utilisation de requêtes préparées permet de se protéger des injections lors de l'accès aux données.

Mise à jour et sécurisation de l'administration

Notion	À retenir
Mise à jour SGBD	Maintenir via les **dépôts officiels** avec installation des **mises à jour de sécurité** (s'appuyer sur guide GNU/Linux, mesures **R58**, **R59**, **R60** et **R61**).
Sécurisation administration	Sécuriser selon les **Recommandations relatives à l'administration sécurisée des SI** en **minimisant les extensions et outils d'administration** utilisés.
Journalisation des accès	Journaliser les événements et accès administrateurs selon l'**annexe A** du guide **Recommandations d'architecture pour la sécurité d'un système de journalisation** (**R3**, **R9**, **R26** et **R27**).

Sécurisation des accès

Notion	À retenir
Comptes d'accès	Utiliser des comptes **distincts** pour les **utilisateurs humains** et les **applications** avec usage défini. Authentification systématique via **mécanismes cryptographiques à l'état de l'art**.
Compte administrateur	Utiliser le compte **administrateur natif** uniquement en **dernier recours** et l'analyser **régulièrement**. Mettre en place une **authentification multifacteur** pour les administrateurs.
Moindre privilège	Limiter les droits des utilisateurs au **strict nécessaire** en définissant des **rôles** affectés aux utilisateurs.

Sauvegarde, protection et supervision

Notion	À retenir
Durcissement de la configuration	Données et **fichiers de configuration** sur partitions/répertoires **distincts** ; désactiver les fonctions lisant, écrivant ou **exécutant des fichiers de l'OS** ; imposer un **typage des données**.
Paramétrage sauvegarde	S'appuyer sur les publications **Les Fondamentaux** et **Les Essentiels** de l'ANSSI sur la sauvegarde des SI.
Protection données	Éviter les données de production en développement. Chiffrement **on-transit** (transmission) et **at-rest** (stockage). Utiliser des **vues** pour limiter l'accès.
Développement et supervision	Utiliser des **requêtes préparées** (injections). Superviser **stockage, CPU, RAM** et auditer les **événements potentiellement suspicieux**.

Mesures de protection des données sensibles

- **Environnements de développement** : ne pas utiliser les données de production pour éviter les fuites.
- **Format SaaS** : porter une attention particulière en raison du risque de **mutualisation entre clients**.
- **Niveaux de sensibilité** : dédier un serveur de base de données par niveau de sensibilité.
- **Mécanismes internes** : utiliser les **vues** pour limiter l'accès aux données.

Pièges et confusions

⚠ Utiliser le compte administrateur natif pour toutes les tâches d'administration par habitude.
⚠ Confondre le risque de mutualisation entre clients du SaaS avec les risques d'une base de données hébergée en propre.
⚠ Mélanger dans un même serveur de base de données des données de niveaux de sensibilité différents.
⚠ Utiliser des données de production dans les environnements de développement.

Sigles et définitions

SGBD	logiciel qui gère une base de données relationnelle
Moindre privilège	limiter les droits des utilisateurs au strict nécessaire, en définissant des rôles affectés aux utilisateurs
Requête préparée	technique de développement permettant de se protéger des injections lors de l'accès à une base de données
SaaS	Software as a Service, mode de mise à disposition d'une base de données présentant un risque de mutualisation entre clients
Chiffrement on-transit	chiffrement lors de la transmission
Chiffrement at-rest	chiffrement lors du stockage

Auto-test

1. Comment doit être maintenu à jour un SGBD ?
2. Quelle technique protège des injections lors de l'accès à une base de données ?
3. À quoi sert le principe de moindre privilège ?
4. Quel est le risque particulier du format SaaS ?
5. Quand doit-on utiliser le compte administrateur natif ?

Réponses : **1.** via les dépôts officiels · **2.** une requête préparée · **3.** limiter les droits des utilisateurs au strict nécessaire · **4.** un risque de mutualisation entre clients · **5.** au dernier recours

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.